CASE STUDY

# Ivanti EPMM Code Injection (CVE-2026-1281 and CVE-2026-1340): A Case Study

*A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.*

## Executive summary

The people on the hook here were the teams who run Ivanti Endpoint Manager Mobile (EPMM) on their own servers: the mobile device management (MDM) system whose database, the Dutch National Cyber Security Centre (NCSC-NL) found, holds device data, directory user data and Office365 tokens and credentials [1] [12] (**Confirmed**). On 29 January 2026 Ivanti disclosed two code injection flaws that let an attacker run code on EPMM without logging in, and said a very limited number of customers had already been exploited [1] (**Confirmed**); the CVE records describe both flaws [2] [3] (**Confirmed**). CISA put CVE-2026-1281 in its Known Exploited Vulnerabilities (KEV) catalog the same day with a three-day deadline [6] [7] (**Confirmed**), and added CVE-2026-1340 on 8 April [6] [8] (**Confirmed**).

Within days, NCSC-NL told every EPMM user to assume breach, reported misuse at several organisations, plausibly by more than one actor, and saw the EPMM database copied out with device data, directory user data and Office365 tokens and credentials in it [12] (**Confirmed**). Dutch ministers later named six public bodies and a municipality where misuse was found or could not be ruled out, among them the data protection authority, the judiciary's council and the prison service [13] [14] (**Confirmed**). Unit 42 reported widespread exploitation and mostly automated exploitation attempts, and its telemetry showed over 4,400 EPMM instances, a count of instances seen rather than of victims [20] (**Reported**). No source opened for this study names the attacker [25] (**Inferred** from absence).

## Key facts at a glance

| Field | Value |
|---|---|
| Product | Ivanti Endpoint Manager Mobile (EPMM), on-premises only; Neurons for MDM (cloud), EPM and Sentry stated unaffected by the vendor [1] |
| CVEs | CVE-2026-1281 and CVE-2026-1340: code injection, unauthenticated remote code execution, CWE-94, CVSS 3.1 9.8 [2] [3] [4] [5] |
| Affected versions | 12.5.0.0, 12.6.0.0 and 12.7.0.0 and prior, 12.5.1.0 and 12.6.1.0 and prior (CCCS); version lists differ across sources (Part 2) [9] [10] [4] [5] |
| Fix | Hotfix RPMs for the 12.x.0.x and 12.x.1.x lines, which do not survive a version upgrade; permanent fix in 12.8.0.0, planned for Q1 2026 (release not checked) [2] [10] |
| KEV | CVE-2026-1281 added 29 Jan 2026, due 1 Feb; CVE-2026-1340 added 8 Apr 2026, due 11 Apr; ransomware use Unknown for both [6] |
| Actor | Not named by any source opened; NCSC-NL judges multiple actors plausible [12] [25] |
| Bodies where misuse was found or not ruled out | Dutch Data Protection Authority, Council for the Judiciary, prison service (DJI), Repatriation and Departure Service, Justice ICT organisation (JIO), Medicines Evaluation Board (CBG), one municipality [13] [14] |

## Key findings

- **One flaw first, then both.** In January CERT-EU said one of the two was exploited in a limited number of cases [10], and Rapid7 called CVE-2026-1281 a confirmed zero-day while it was unclear whether CVE-2026-1340 was exploited [21] (**Confirmed**; Rapid7 **Reported**). By 8 April Canada's Cyber Centre relayed that Ivanti says both were exploited, and KEV listed CVE-2026-1340 that day [6] [9] (**Confirmed**).
- **The vendor's scale and the field's scale disagree.** Ivanti's "very limited number of customers" [1] sits against NCSC-NL's multi-organisation, plausibly multi-actor misuse [12] and Unit 42's widespread exploitation and mostly automated attempts in five sectors and four countries, with over 4,400 EPMM instances seen in its telemetry, not a victim count [20] (**Inferred** comparison; Unit 42 **Reported**).
- **The prize was the MDM database.** NCSC-NL saw the database copied and exfiltrated with device data, LDAP user data and Office365 tokens and credentials [12] (**Confirmed**). A later revision warned that a compromised EPMM can reach Ivanti Sentry through the EPMM keystore [11] (**Confirmed**), although the vendor lists Sentry as unaffected by the CVEs themselves [1].
- **Patching did not close the case.** NCSC-NL said patching does not remove earlier compromise, advised reinstalling, warned that configuration backups may have been taken too and said a clean result from Ivanti's detection RPM is no guarantee [12] (**Confirmed**).
- **The fix could quietly come undone.** The hotfix RPM does not survive a version upgrade and must be reapplied [10] (**Confirmed**); watchTowr criticised fixes that can be rolled back [22] (**Reported**).

### Top recommendations

1. Treat any on-premises EPMM that was internet-reachable on an affected build as possibly compromised, and investigate before or alongside patching: secure forensic evidence first, as CERT-EU advises [10], and report to your national CERT even after patching, as NCSC-NL asks [12] (**Confirmed** as their guidance).
2. Reinstall rather than clean in place, treat configuration backups as exposed because NCSC-NL says they can also be taken, and rotate all secrets [12] (**Confirmed** as NCSC-NL's guidance), starting with the LDAP credentials and Office365 tokens the database held (**Inferred** from [12]).
3. Check Ivanti Sentry for suspicious access originating from EPMM [11] (**Confirmed** as NCSC-NL's guidance).
4. Confirm after every EPMM version upgrade that the hotfix RPM is still in place, until you run 12.8.0.0 or later [10] (**Confirmed** as CERT-EU's relay of the vendor; whether 12.8.0.0 shipped is not checked).
5. Read SSVC and KEV together: CISA's enrichment marked both CVEs exploitation active, automatable, total impact [2] [3], which matches the three-day KEV windows [6] (**Inferred**; CISA states no rationale).

## Scope and method

This brief covers the two EPMM code injection CVEs from their reservation on 21 and 22 January 2026 to the KEV catalog of 10 November 2026, with the earlier EPMM record (2023 to 2025) as lineage and the May 2026 EPMM flaw as a coda. It describes tradecraft at advisory level: no request formats, endpoints or exploit steps. All times are UTC.

| Grade | Meaning in this study |
|---|---|
| Confirmed | Stated in a primary opened for this study: Ivanti's own post, the CVE and NVD records, the CISA KEV catalog and alerts, national CERT advisories, Dutch government letters and reports, and the European Commission's release |
| Reported | Known through journalism or vendor research about other organisations' systems (NOS, Unit 42, Rapid7, EclecticIQ) |
| Demonstrated | Shown by a researcher's own technical analysis (watchTowr's root-cause work), or by this study's check of the library's ATT&CK, CWE, CAPEC and D3FEND data files |
| Inferred | This study's own reasoning from cited facts, labelled where it appears |

Ivanti's security advisory and its Analysis Guidance page could not be opened (the support hub renders only a script shell), so their contents are known through the CVE records, KEV notes and the national CERTs [1] [2] [6] [9] [10].

## Part 1: what happened

| Date | Event | Sources | Grade |
|---|---|---|---|
| 21 Jan 2026, 03:38 | Ivanti reserves CVE-2026-1281 | [2] | Confirmed |
| 22 Jan 2026, 14:59 | Ivanti reserves CVE-2026-1340 | [3] | Confirmed |
| 29 Jan 2026 | Ivanti publishes its January 2026 EPMM Security Update and advisory: a very limited number of customers exploited; on-premises EPMM only | [1] [9] | Confirmed |
| 29 Jan 2026 | Ivanti notifies NCSC-NL, according to the Dutch government | [13] | Confirmed |
| 29 Jan 2026, 21:31 and 21:33 | Ivanti publishes the two CVE records; NVD publishes both at 22:15 | [2] [3] [4] [5] | Confirmed |
| 29 Jan 2026 | KEV adds CVE-2026-1281, due 1 Feb; CISA alert cites evidence of active exploitation; Canada issues AV26-068 with Update 1 | [6] [7] [9] | Confirmed |
| 29 and 30 Jan 2026 | CISA's SSVC enrichment marks CVE-2026-1281 exploitation active (30 Jan, 04:55); the CVE-2026-1340 entry carries a date-only 29 Jan stamp in a container last updated 9 Apr | [2] [3] | Confirmed |
| 30 Jan 2026 | CERT-EU Security Advisory 2026-001 (09:09): one flaw exploited in a limited number of cases | [10] | Confirmed |
| 30 Jan 2026 | Rapid7 calls CVE-2026-1281 a confirmed zero-day and reports public proof-of-concept code; watchTowr publishes its root-cause analysis | [21] [22] | Reported; Demonstrated |
| 30 Jan 2026 | The European Commission's central MDM infrastructure finds traces of a cyber-attack, contained within 9 hours; the release does not name Ivanti or EPMM | [18] | Confirmed |
| 2 Feb 2026 | NCSC-NL warning: assume breach and make contact even after patching | [12] | Confirmed |
| 4 Feb 2026 | NCSC-NL update: misuse far wider than known; patching does not undo earlier compromise | [12] | Confirmed |
| 4 Feb 2026 | NCSC-2026-0043 revision 1.0.1 records public PoC code for CVE-2026-1281 | [11] | Confirmed |
| 6 Feb 2026 | Dutch government letter (Kamerstuk 26643 nr. 1462) names the Data Protection Authority and the Council for the Judiciary as affected | [13] | Confirmed |
| 9 Feb 2026 | NCSC-NL update: misuse at several organisations; MIFS database copied and exfiltrated; multiple actors plausible; reinstall | [12] | Confirmed |
| 16 Feb 2026 | NCSC-NL gives the prison service DJI a course of action | [15] | Confirmed |
| 17 Feb 2026 | Unit 42 threat brief: over 4,400 EPMM instances in Unit 42 telemetry; widespread exploitation, mostly automated attempts | [20] | Reported |
| 20 Feb 2026 | NCSC-2026-0043 revision 1.0.2: a compromised EPMM can give access to Ivanti Sentry through the EPMM keystore | [11] | Confirmed |

| Date | Event | Sources | Grade |
|---|---|---|---|
| 27 Feb 2026 | Kamerstuk 26643 nr. 1492 lists six bodies and a municipality; police reports filed. NOS reports at least five months of access at DJI | [14] [19] | Confirmed; NOS Reported |
| 24 Mar 2026 | Unit 42 stops monitoring the activity | [20] | Reported |
| 8 Apr 2026 | KEV adds CVE-2026-1340, due 11 Apr, citing hotfix RPM build 1.1.0; CISA alert; Canada's Update 2 relays that Ivanti says both CVEs were exploited | [6] [8] [9] | Confirmed |
| 13 Apr 2026 | Parliamentary answers: JIO hired an external forensic firm; DJI staff face added risk of blackmail and extortion | [15] | Confirmed |
| 7 May 2026 | A later EPMM flaw, CVE-2026-6973, enters KEV | [6] | Confirmed |
| 20 May 2026 | The Justice and Security 2025 annual report records that DJI was hit via the Ivanti hack | [16] | Confirmed |
| 17 Jun 2026 | NVD last modifies both records, status Analyzed | [4] [5] | Confirmed |
| 25 Jun 2026 | The Dutch parliamentary Digital Affairs committee debates letters 1462 and 1492 | [17] | Confirmed |

### Discrepancies in the record

- **Affected versions.** Canada lists 12.5.0.0, 12.6.0.0 and 12.7.0.0 and prior, plus 12.5.1.0 and 12.6.1.0 and prior [9]; CERT-EU lists only 12.5.1.0, 12.6.1.0 and 12.7.0.0 and prior [10]; NVD's configuration for CVE-2026-1281 names versions up to 12.5.0.0 plus 12.5.1.0, 12.6.0.0, 12.6.1.0 and 12.7.0.0, and for CVE-2026-1340 everything up to 12.7.0.0 [4] [5] (**Confirmed**). Every list covers release lines up to 12.7.0.0, and none lists 12.8.0.0 (**Inferred**).
- **Exploited when.** CISA's SSVC entry for CVE-2026-1340 carries a date-only 29 January timestamp with exploitation active, but the CISA-ADP container was last updated on 9 April, the day after the KEV addition [3] [6] (**Confirmed**). The record therefore does not show when the active rating was first set (**Inferred**).
- **Proof-of-concept date.** Rapid7 reports public PoC code by 30 January [21] (**Reported**); NCSC-NL records it in its 4 February revision [11] (**Confirmed**).
- **How long at DJI.** NOS reports at least five months of access [19] (**Reported**). If accurate, access would predate the January disclosure, but the government record opened for this study does not state the figure [14] [15] [16] (**Inferred**).

## Part 2: the technical record

| CVE | CNA, published | Weakness | CVSS 3.1 (CNA) | Fix | CISA SSVC | KEV |
|---|---|---|---|---|---|---|
| CVE-2026-1281 | Ivanti, 29 Jan 21:31 | CWE-94, code injection; CAPEC-242 | 9.8, AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H | 12.x.0.x and 12.x.1.x hotfix RPMs; KEV notes cite build 1.0.0 (AB1771634) | Active, automatable, total | 29 Jan, due 1 Feb |
| CVE-2026-1340 | Ivanti, 29 Jan 21:33 | CWE-94, code injection; CAPEC-242 | 9.8, same vector | Same RPM lines; KEV notes cite build 1.1.0 (AB1786671) | Active, automatable, total | 8 Apr, due 11 Apr |

Sources: the CVE records [2] [3], NVD [4] [5] and the KEV catalog [6] (**Confirmed**). The CVE records list the finder as UNKNOWN for both [2] [3] (**Confirmed**).

**The flaw, at advisory level.** Ivanti's records describe both CVEs as code injection in EPMM that lets an attacker achieve remote code execution without authentication [2] [3] (**Confirmed**). watchTowr places the flaws in the web tier's app store and file transfer handling, reachable without authentication [22] (**Demonstrated**). This study does not reproduce request details.

**The fix and its catch.** The CVE records mark the hotfix states "12.x.0.x RPM" and "12.x.1.x RPM" as unaffected, with every other state affected by default [2] [3] (**Confirmed**). The KEV notes for January and April cite different support articles and RPM builds (1.0.0 and 1.1.0) [6] (**Confirmed**), which indicates Ivanti reissued the RPM between January and April (**Inferred**; the advisory was not opened to confirm).

**What attackers did after getting in.** Beyond the database theft NCSC-NL saw [12] (**Confirmed**), Unit 42 saw reverse-shell attempts, attempts to download the Nezha monitoring agent, and second-stage scripts that typically install a web shell, a cryptominer or a persistent backdoor, and warned of dormant backdoors meant to outlast patching [20] (**Reported**). NOS reports the attackers may have been able to manage devices remotely [19] (**Reported**). The mix of data theft and cryptomining fits NCSC-NL's assessment that more than one actor plausibly exploited the flaw (**Inferred**).

## Part 3: who and why

No source opened for this study attributes the 2026 EPMM exploitation to a named actor or country. Ivanti, CISA, CERT-EU, NCSC-NL, Canada's Cyber Centre, the Dutch government, the European Commission, Unit 42, Rapid7 and watchTowr are all silent on attribution, and NOS names no attacker [25] (**Inferred** from absence across [1] to [22]). NCSC-NL considers it plausible that multiple actors were behind the misuse it saw [12] (**Confirmed**). NCSC-NL also notes that the method resembles misuse of earlier Ivanti flaws but says it is not clear whether the same actor is involved [12] (**Confirmed**).

The EPMM line has a state-actor history, which is why the silence matters:

- **2023.** CISA and Norway's NCSC report that unnamed APT actors exploited CVE-2023-35078 as a zero-day from at least April 2023, chained with CVE-2023-35081, against Norwegian organisations including a government agency [23] (**Confirmed**). The library's The Year 2023 in Intrusions records that round in its dated timeline.
- **2025.** EclecticIQ attributes exploitation of the CVE-2025-4427 and CVE-2025-4428 chain, from 15 May 2025, "with high confidence" to an unnamed China-nexus espionage group [24] (**Reported**). That assessment covers the 2025 chain only and must not be carried over to 2026 (**Inferred**).

The library's Threat Actors: China covers the Ivanti Connect Secure lineage, including the Cutting Edge campaign and UNC5221's exploitation of CVE-2025-0282 [27] (**Confirmed**). The library's Ivanti Connect Secure zero-day chain of October 2026 study covers the later Connect Secure round of the same year. Those are a different Ivanti product and are linked here for lineage only, not as attribution for EPMM. The data stolen (directory users, tokens, staff contact and location data) would serve espionage, extortion or resale equally, and the cryptominers Unit 42 saw point to opportunists as well [12] [14] [20] (**Inferred**).

## Part 4: impact and response

**Victims.** The Dutch government record is the fullest list. Its 6 February letter says unauthorised parties viewed Data Protection Authority staff names, business email addresses and phone numbers, and that the Council for the Judiciary filed a provisional breach notification [13] (**Confirmed**). The 27 February letter adds the bodies listed in the key facts, says DJI staff names, emails, phone numbers and location data were viewed, and records police reports [14] (**Confirmed**). The government told parliament DJI staff face added risk of blackmail and extortion but saw no signals yet of consequences for their safety [15] (**Confirmed**). The ministry's 2025 annual report records that emails, phone numbers and security certificates of DJI's phone, tablet and laptop users leaked [16] (**Confirmed**).

The European Commission's central MDM infrastructure found traces of an attack on 30 January, the day after disclosure; staff names and mobile numbers may have been accessed, the incident was contained within 9 hours, and no device compromise was detected [18] (**Confirmed**). The release does not name Ivanti or EPMM, so any link rests on timing alone (**Inferred**). The library's European Commission cloud breach of 2026 study, about a separate breach, mentions this MDM incident only as context.

Beyond named bodies, Unit 42 saw victims in state and local government, healthcare, manufacturing, professional and legal services, and high tech, in the US, Germany, Australia and Canada [20] (**Reported**).

**The vendor.** Ivanti's 29 January post named neither attacker nor partners and linked log analysis guidance whose contents were not checked [1] (**Confirmed** that the links exist).

**CISA and KEV.** The required action is to apply mitigations per vendor instructions, follow BOD 22-01 guidance for cloud services, or discontinue use if mitigations are unavailable, and the notes ask defenders to check all internet-accessible affected Ivanti products for signs of compromise [6] (**Confirmed**).

| EPMM line in KEV (catalog 2026.11.10) | Added | Class |
|---|---|---|
| CVE-2023-35078 | 25 Jul 2023 | Authentication bypass; ransomware Known |
| CVE-2023-35081 | 31 Jul 2023 | Path traversal |
| CVE-2023-35082 | 18 Jan 2024 | Authentication bypass; ransomware Known |
| CVE-2025-4427 and CVE-2025-4428 | 19 May 2025 | Authentication bypass (CWE-288) and code injection (CWE-94) |
| CVE-2026-1281 | 29 Jan 2026 | Code injection (CWE-94) |
| CVE-2026-1340 | 8 Apr 2026 | Code injection (CWE-94) |
| CVE-2026-6973 | 7 May 2026 | Improper input validation (CWE-20), authenticated admin to RCE |
| CVE-2023-38035 (Ivanti Sentry, related) | 22 Aug 2023 | Not detailed here; ransomware Known |
| CVE-2026-10520 (Ivanti Sentry, related) | 11 Jun 2026 | Not detailed here |

Source: the KEV catalog [6] (**Confirmed**).

## Part 5: the defender and vulnerability-management view

An MDM server is a directory of the organisation's people and devices with the keys to reach them. NCSC-NL's list of what was taken (device data, directory users, cloud tokens and credentials) and its Sentry warning make clear that an EPMM compromise is an identity incident, not just a server incident [11] [12] (**Inferred**).

| Control | Where it meets the record |
|---|---|
| Patch, then confirm the RPM survived each upgrade | The RPM does not survive a version upgrade; the permanent fix is 12.8.0.0 [10] |
| Investigate before trusting the patch | NCSC-NL: patching does not remove earlier compromise; report even after patching [12] |
| Preserve evidence before rebuilding | CERT-EU's first recommendation [10] |
| Reinstall, and treat configuration backups as exposed | NCSC-NL: backup configurations can also be taken [12] |
| Do not treat a clean detection RPM as proof | NCSC-NL [12] |
| Rotate every secret EPMM held: user passwords, private keys, Office365 tokens and certificates | What was in the MIFS database [12]; DJI certificates leaked [16] |
| Check Sentry for access from EPMM | NCSC-2026-0043 revision 1.0.2 [11] |
| Hunt for web shells, miners and unknown agents on EPMM hosts | Unit 42's post-exploitation list [20] |
| Order work by SSVC plus KEV | Active, automatable, total on both CVEs [2] [3]; three-day KEV windows [6] |

A scanner that reads only the EPMM version string can be wrong in both directions here: it can flag a patched 12.x server as vulnerable because the fix is an RPM, and miss a server whose upgrade silently removed the RPM [2] [10] (**Inferred**).

### What is overstated and what is understated

- **Overstated:** calling both CVEs confirmed January zero-days. CERT-EU's January advisory says one was exploited [10], Rapid7 confirmed only CVE-2026-1281 [21], and CVE-2026-1340 entered KEV on 8 April [6] (**Confirmed**); its SSVC entry's date-only 29 January stamp sits in a record updated on 9 April [3] (**Inferred**). Tying the European Commission incident to EPMM also goes past the record, which names neither Ivanti nor EPMM [18] (**Inferred**). Attributing 2026 to the China-nexus group EclecticIQ named for 2025 is unsupported [24] [25] (**Inferred**).
- **Understated:** Ivanti's "very limited number of customers" [1] against six Dutch public bodies and a municipality where misuse was found or could not be ruled out [14], NCSC-NL's plausibly multi-actor misuse and database theft [12] and Unit 42's widespread exploitation and mostly automated attempts [20] (**Inferred** comparison). The RPM that does not survive upgrades [10] and the EPMM-to-Sentry path [11] are easy to miss and outlast the patch (**Inferred**).

## MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files, and every linked page exists in the library's `mitre/` tree [26] (**Demonstrated**). No source names ATT&CK ids for this activity, so every technique below is this study's mapping of a described behavior (**Inferred**); the CWE and CAPEC ids are the CNA's own [2] [3]. No industrial system is involved, so no ATT&CK for ICS techniques apply. EPMM manages mobile devices, but no source describes actions on the managed devices themselves, so no ATT&CK for Mobile techniques are bound.

### Groups, software and campaigns

ATT&CK has no group object for the 2026 EPMM actors, who are unnamed, and no software object for the Nezha agent [26] (**Demonstrated**), so none is bound. One object is related, not bound:

| Object | ATT&CK id | Relationship to this record |
|---|---|---|
| Cutting Edge | C0029 | The Ivanti Connect Secure zero-day campaign covered in Threat Actors: China [27]. A different Ivanti product; lineage only, not attribution |

## ATT&CK Enterprise techniques

| ID | Name | Tactic(s) | Dated event or report | Sources |
|---|---|---|---|---|
| T1190 | Exploit Public-Facing Application | Initial Access | Unauthenticated code injection in EPMM; KEV 29 Jan and 8 Apr 2026 | [2] [3] [6] |
| T1587.004 | Exploits | Resource Development | CVE-2026-1281 exploited before disclosure as a zero-day (Rapid7, 30 Jan) | [1] [21] |
| T1588.005 | Exploits | Resource Development | Public PoC available (Rapid7, 30 Jan; NCSC-NL rev 1.0.1, 4 Feb) ahead of widespread, mostly automated exploitation (Unit 42, 17 Feb) | [11] [20] [21] |
| T1059 | Command and Scripting Interpreter | Execution | Reverse-shell attempts through injected commands (Unit 42, 17 Feb) | [20] |
| T1505.003 | Web Shell | Persistence | JSP web shells (Unit 42, 17 Feb) | [20] |
| T1105 | Ingress Tool Transfer | Command and Control | Second-stage script and Nezha agent download attempts (Unit 42, 17 Feb) | [20] |
| T1219 | Remote Access Tools | Command and Control | Attempts to download and run the Nezha monitoring agent (Unit 42, 17 Feb) | [20] |
| T1496.001 | Compute Hijacking | Impact | Cryptominers (Unit 42, 17 Feb) | [20] |
| T1005 | Data from Local System | Collection | MIFS database copied (NCSC-NL update, 9 Feb) | [12] |
| T1070 | Indicator Removal | Stealth | At least one actor observed wiping its traces (NCSC-NL update, 9 Feb) | [12] |
| T1552 | Unsecured Credentials | Credential Access | LDAP user data and Office365 credentials in the exfiltrated database (NCSC-NL update, 9 Feb) | [12] |
| T1528 | Steal Application Access Token | Credential Access | Office365 tokens in the exfiltrated database (NCSC-NL update, 9 Feb) | [12] |
| T1552.004 | Private Keys | Credential Access | DJI security certificates leaked (annual report, 20 May); NCSC-NL also warns the EPMM keystore can reach Sentry (rev 1.0.2, 20 Feb) | [16] [11] |

Fit notes (**Inferred**): T1587.004 is bound because the first exploitation preceded disclosure; who built the exploit is unknown. T1588.005 reflects the public PoC that Unit 42's automated wave followed, not a proven link. T1059 is bound at the parent because the sources do not name the interpreter. T1219 rests on Unit 42's report of attempts to download and run the Nezha agent; T1105 on the same attempts and the second-stage script downloads. T1070 rests on NCSC-NL's observation that at least one actor wiped its traces; the method is not described, so the parent is bound. T1552.004 is bound on the DJI certificate leak [16]; the Sentry keystore path is a warning, not an observed act [11]. T1072 Software Deployment Tools is considered but not bound: NOS reports only that attackers may have been able to manage DJI devices [19] (**Reported**). No exfiltration technique is bound: NCSC-NL saw the database exfiltrated but no source names the channel. The dormant backdoors Unit 42 mentions are not bound because their mechanism is not described.

## CWE and CAPEC

| CWE | Name | Where it is assigned | Sources |
|---|---|---|---|
| CWE-94 | Improper Control of Generation of Code | Both CVE records, NVD and both KEV entries | [2] [3] [4] [5] [6] |

| CAPEC | Name | Via | Where it meets the record |
|---|---|---|---|
| CAPEC-242 | Code Injection | CWE-94; mapped by the Ivanti CNA in both CVE records | The unauthenticated code injection itself [2] [3] |

The library also relates CAPEC-35 and CAPEC-77 to CWE-94, but no record for these CVEs supports them, so they are not bound [26] (**Demonstrated**). The lineage CWEs (CWE-288 for CVE-2025-4427, CWE-20 for CVE-2026-6973) belong to other CVEs and are not bound here [6]. See the CWE Reference and CAPEC Reference.

## D3FEND countermeasures

| D3FEND countermeasure | Techniques the library maps it to (from this study) | Where it meets the record |
|---|---|---|
| Software Update | T1072 in the library, not bound here; listed for the vendor fix and NCSC-NL's reinstall advice | The hotfix RPM and 12.8.0.0 [10] (**Inferred** fit for T1190, which the library does not map) |
| Restore Software | T1072 in the library, not bound here; listed for the vendor fix and NCSC-NL's reinstall advice | NCSC-NL's advice to reinstall rather than clean in place [12] |
| Credential Rotation, with Credential Revocation and Reissue Credential | T1552, T1528 | NCSC-NL: rotate all secrets [12] |
| Authentication Cache Invalidation | T1552, T1528 | Invalidating the Office365 tokens held in the stolen database [12] (**Inferred**) |
| Credential Compromise Scope Analysis | T1552, T1528 | Scoping what the MIFS database exposed, and checking Sentry [11] [12] (**Inferred**) |
| File Integrity Monitoring and File Analysis | T1505.003 | Finding JSP web shells on EPMM hosts [20] (**Inferred**) |
| Network Traffic Filtering and Outbound Traffic Filtering | T1190, T1219 | Limiting reach to and from EPMM: reverse-shell and Nezha agent download attempts [20] (**Inferred**) |
| Client-server Payload Profiling | T1190 | Ivanti's log analysis guidance, whose contents were not checked [1] (**Inferred**) |

See the D3FEND Reference.

### Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/ivanti-epmm-cve-2026-1281.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 75 means a CVE record, KEV entry or government advisory describes the behavior; 50 means vendor research describes it; 25 means a capability, a warning or a Reported possibility rather than an observed act (T1587.004, T1588.005). T1552.004 scores 75 on the DJI certificate leak in the ministry's annual report. Each comment names the event and the source numbers.

## Cross-cutting themes

- **MDM is identity infrastructure.** The data taken was directory users, tokens, staff contact and location data and certificates [12] [14] [16] (**Confirmed**); the response that worked was the one built for an identity breach, rotate and rebuild (**Inferred**). MDM servers have been targets before: the library's Log4Shell study records MobileIron Core exploitation in 2021 and 2022 [28] (**Confirmed**).
- **Hotfixes that do not persist are a vulnerability-management trap.** A version-based program cannot see an RPM that an upgrade removed [10] (**Inferred**).
- **Government records measured scale best.** Government victim lists and national CERT warnings were the better measure of scale than vendor statements [12] [14] (**Inferred**).
- **Silence on attribution is a finding.** With state actors behind the 2023 and 2025 EPMM rounds [23] [24], the absence of any named actor in 2026 should be reported as such, not filled in (**Inferred**).
- **The same product keeps returning.** Eight EPMM entries in KEV since July 2023, plus two related Sentry entries [6], make EPMM a standing exposure, not a one-off (**Inferred**). See Threat Actors: China and the Ivanti Connect Secure zero-day chain of October 2026 for the parallel Connect Secure record.

## Sources

All sources were opened on 11 November 2026.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | Ivanti, January 2026 EPMM Security Update, 29 Jan 2026 | ivanti.com/blog/january-2026-epmm-security-update | 2026-11-11 | Confirmed |
| 2 | CVE Program record CVE-2026-1281 (CNA Ivanti, with CISA ADP) | cveawg.mitre.org/api/cve/CVE-2026-1281 | 2026-11-11 | Confirmed |
| 3 | CVE Program record CVE-2026-1340 (CNA Ivanti, with CISA ADP) | cveawg.mitre.org/api/cve/CVE-2026-1340 | 2026-11-11 | Confirmed |
| 4 | NVD, CVE-2026-1281 | services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-1281 | 2026-11-11 | Confirmed |
| 5 | NVD, CVE-2026-1340 | services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-1340 | 2026-11-11 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 6 | CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10 | cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json | 2026-11-11 | Confirmed |
| 7 | CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 29 Jan 2026 | cisa.gov/news-events/alerts/2026/01/29/... | 2026-11-11 | Confirmed |
| 8 | CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 8 Apr 2026 | cisa.gov/news-events/alerts/2026/04/08/... | 2026-11-11 | Confirmed |
| 9 | Canadian Centre for Cyber Security, Ivanti security advisory AV26-068, 29 Jan 2026, Update 2 8 Apr 2026 | cyber.gc.ca/en/alerts-advisories/ivanti-security-advisory-av26-068 | 2026-11-11 | Confirmed |
| 10 | CERT-EU, Security Advisory 2026-001, Critical vulnerabilities in Ivanti EPMM, 30 Jan 2026 | cert.europa.eu/publications/security-advisories/2026-001/ | 2026-11-11 | Confirmed |
| 11 | NCSC-NL, advisory NCSC-2026-0043 (CSAF), revisions to 1.0.2, 20 Feb 2026 | advisories.ncsc.nl/csaf/v2/2026/ncsc-2026-0043.json | 2026-11-11 | Confirmed |
| 12 | NCSC-NL, warning to organisations using Ivanti Endpoint Manager Mobile, 2 Feb 2026, updated through 12 Feb 2026 | ncsc.nl/waarschuwing/ncsc-roept-organisaties-op-... | 2026-11-11 | Confirmed |
| 13 | Dutch government, Kamerstuk 26643 nr. 1462, 6 Feb 2026 | zoek.officielebekendmakingen.nl/kst-26643-1462.html | 2026-11-11 | Confirmed |
| 14 | Dutch government, Kamerstuk 26643 nr. 1492, 27 Feb 2026 | zoek.officielebekendmakingen.nl/kst-26643-1492.html | 2026-11-11 | Confirmed |
| 15 | Dutch government, answers to parliamentary questions, Aanhangsel 2025-2026 nr. 1599, 13 Apr 2026 | zoek.officielebekendmakingen.nl/ah-tk-20252026-1599.html | 2026-11-11 | Confirmed |
| 16 | Ministry of Justice and Security, annual report 2025, Kamerstuk 36945 VI nr. 1, 20 May 2026 | zoek.officielebekendmakingen.nl/kst-36945-VI-1.html | 2026-11-11 | Confirmed |
| 17 | Tweede Kamer, Digital Affairs committee debate report, debate of 25 Jun 2026 | zoek.officielebekendmakingen.nl/kst-1270165.html | 2026-11-11 | Confirmed |
| 18 | European Commission, press release IP/26/342, 6 Feb 2026, on the 30 Jan 2026 MDM incident | ec.europa.eu/commission/presscorner/detail/en/ip_26_342 | 2026-11-11 | Confirmed |
| 19 | NOS, report on the Argos investigation into five months of access to DJI staff data, 27 Feb 2026 | nos.nl/artikel/2604180-... | 2026-11-11 | Reported |
| 20 | Unit 42 (Palo Alto Networks), threat brief on CVE-2026-1281 and CVE-2026-1340, 17 Feb 2026, monitoring stopped 24 Mar 2026 | unit42.paloaltonetworks.com/ivanti-cve-2026-1281-cve-2026-1340/ | 2026-11-11 | Reported |
| 21 | Rapid7, ETR on the Ivanti EPMM zero-day exploited in the wild, 30 Jan 2026 | rapid7.com/blog/post/etr-critical-ivanti-endpoint-manager-mobile-... | 2026-11-11 | Reported |
| 22 | watchTowr Labs, analysis of the Ivanti EPMM pre-auth RCEs CVE-2026-1281 and CVE-2026-1340, 30 Jan 2026 | labs.watchtowr.com/someone-knows-bash-far-too-well-... | 2026-11-11 | Demonstrated |
| 23 | CISA and NCSC-NO, joint advisory AA23-213A on EPMM exploitation, 1 Aug 2023 | cisa.gov/news-events/cybersecurity-advisories/aa23-213a | 2026-11-11 | Confirmed |
| 24 | EclecticIQ, report on China-nexus exploitation of Ivanti EPMM CVE-2025-4428, 21 May 2025 | blog.eclecticiq.com/china-nexus-threat-actor-... | 2026-11-11 | Reported |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 25 | This study's review of sources [1] to [22] for any attribution of the 2026 exploitation | (derived from the sources above) | 2026-11-11 | Inferred |
| 26 | TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` page tree | github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack | 2026-11-11 | Demonstrated |
| 27 | TeamStarWolf, Threat Actors: China | /case-studies/THREAT_ACTORS_CHINA.md | 2026-11-11 | Confirmed |
| 28 | TeamStarWolf, Log4Shell (CVE-2021-44228): The Case Study | /case-studies/LOG4SHELL.md | 2026-11-11 | Confirmed |

The Team Star Wolf Intelligence Hub feed indexes KEV rows for both CVEs and the Canadian AV26-068 row, and has no news rows on these events; it was used as an index, not a source.

Not opened, so not cited as sources: Ivanti's security advisory and Analysis Guidance on its support hub (rendered only a script shell), the hotfix RPM downloads, the Dutch Data Protection Authority's own statement (HTTP 403), Finland's national CERT (HTTP 403 and 404), and Shadowserver's exposure counts. Whether 12.8.0.0 shipped is not checked.

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- Threat Actors: China, Log4Shell, The Year 2023 in Intrusions, The Year 2026 in Intrusions, Timeline
- Other 2026 studies of exploited edge and management products: The Ivanti Connect Secure zero-day chain, The BeyondTrust Remote Support and PRA command injection, The Dell RecoverPoint for Virtual Machines hard-coded credential zero-day, The FortiCloud SSO authentication bypass, The Citrix NetScaler zero-days, and, for the Commission's own later breach, The European Commission cloud breach of 2026
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Mobile Security Reference, Edge Device Security Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference

- Campaigns (lineage only): C0029 Cutting Edge
- Techniques: T1190 Exploit Public-Facing Application, T1587.004 Exploits, T1588.005 Exploits, T1059 Command and Scripting Interpreter, T1505.003 Web Shell, T1105 Ingress Tool Transfer, T1219 Remote Access Tools, T1496.001 Compute Hijacking, T1005 Data from Local System, T1070 Indicator Removal, T1552 Unsecured Credentials, T1528 Steal Application Access Token, T1552.004 Private Keys
- CAPEC: CAPEC-242 Code Injection
- Navigator layers, including this study's layer, ivanti-epmm-cve-2026-1281.json
- The Team Star Wolf Intelligence Hub
- All case studies